

用户管理系统 — 完整安全审计报告

项目名称：Flask 用户信息管理平台

审计日期：2026-07-13

漏洞总数：7

严重漏洞：4 | 中危漏洞：2 | 低危漏洞：1

漏洞清单

编号	漏洞类型	位置	严重性
V-001	IDOR 越权访问	/profile?user_id=	严重
V-002	负金额充值	/recharge	严重
V-003	SQL注入 (搜索)	/?keyword=	严重
V-004	路径穿越	/page?name=../	严重
V-005	任意文件上传	/upload	中危
V-006	注册SQL注入	/register	严重
V-007	明文密码存储	SQLite 数据库	中危

1. V-001 IDOR 越权访问

CWE: CWE-639: Authorization Bypass Through User-Controlled Key

CVSS: 8.6 (High)

漏洞代码

```
@app.route("/profile")
def profile():
    user_id = request.args.get("user_id", "") # ← 从URL参数获取
    c.execute("SELECT ... FROM users WHERE id=?", (user_id,))
```

问题：user_id 从 URL 参数获取，未验证当前登录用户和查询的 **user_id** 是否匹配。任意登录用户只需修改 URL 中的 user_id 即可查看任何人的资料。

POC

```
# 以 admin 身份登录，查看 admin 资料
curl "http://127.0.0.1:5000/profile?user_id=1"

# IDOR：查看 alice 的资料（无需 alice 密码）
curl "http://127.0.0.1:5000/profile?user_id=2"
```

修复

```
# ☒ 从 session 获取当前用户
username = session.get("username")
c.execute("SELECT * FROM users WHERE username=?", (username,))
```

2. V-002 负金额充值

CWE: CWE-1285: Improper Validation of Specified Quantity in Input

CVSS: 9.1 (Critical)

漏洞代码

```
@app.route("/recharge", methods=["POST"])
def recharge():
    amount = request.form.get("amount", "0")
    c.execute("UPDATE users SET balance = balance + ? WHERE id=?", (amount, user_id))
```

问题：amount 参数未做正负校验，攻击者可传入负数来"充值"，从而减少任意用户余额。

POC

```
# 正常充值
curl -X POST -d "user_id=1&amount=100" http://127.0.0.1:5000/recharge
```

```
# 负金额攻击：扣减余额
```

```
curl -X POST -d "user_id=1&amount=-99999" http://127.0.0.1:5000/recharge
```

修复

```
# ☒ 校验金额必须为正数
```

```
amount = float(request.form.get("amount", "0"))
```

```
if amount <= 0:
```

```
    return render_template("profile.html", error="金额必须为正数")
```

3. V-003 搜索功能 SQL 注入

4. V-004 路径穿越漏洞

5. V-005 任意文件上传

6. V-006 注册功能 SQL 注入

7. V-007 明文密码存储

(V-003 至 V-007 的详细分析见 docs/ 目录下的完整版报告)

修复方法汇总

漏洞	问题	修复方案
V-001 IDOR	user_id 从 URL 获取	从 session 获取当前用户
V-002 负金额	amount 无正负校验	检查 amount > 0
V-003 SQL注入	f-string 拼接	参数化查询
V-004 路径穿越	os.path.join 直接拼接	realpath + 前缀校验
V-005 文件上传	无校验	后缀白名单

漏洞	问题	修复方案
V-006 SQL注入	f-string 拼接	参数化查询
V-007 明文密码	明文存储	generate_password_hash

报告日期：2026-07-13